

Truyền tệp (File Transfers)

HTB Academy • Bản ghi chép hoàn chỉnh của mô-đun

Tổng quan mô-đun

- **Độ khó:** Trung bình
- **Cấp:** Tier 0
- **Thời gian dự kiến:** 3 giờ
- **Lần cập nhật gần nhất được ghi nhận:** 4 năm trước
- **Cấu trúc:** 10 phần • 2 bài thực hành cuối được xen kẽ • 0 bài đánh giá
- **Kiến thức tiên quyết được đề cập:** Introduction to Networking, Linux Fundamentals, Web Requests
- **Huy hiệu/Cubes:** 10 cubes

Mô tả

Mô-đun tập trung vào truyền tệp trong quá trình đánh giá bảo mật, bao gồm các phương pháp trên Windows và Linux, sử dụng tiện ích có sẵn, máy chủ web, kỹ thuật tận dụng công cụ sẵn có trên hệ thống (Living off the Land), phát hiện và kiến thức cơ bản về né tránh phát hiện.

Tóm lược mô-đun

Mô-đun xây dựng vốn phương pháp thực tế để chuyển tệp giữa máy tấn công và mục tiêu trong môi trường bị hạn chế. Nội dung bao gồm tải xuống và tải lên trên Windows, Linux; dùng ngôn ngữ lập trình làm kênh truyền; phương pháp thay thế với Netcat, WinRM, RDP; bảo vệ tệp nhạy cảm; tải lên qua HTTP/S; các chương trình thuộc [LAB_CREDENTIAL_REDACTED]; cùng dữ liệu giám sát mà những phương pháp này để lại cho đội phòng thủ.

Danh sách các phần

- **Phần 01** — Truyền tệp
- **Phần 02** — Các phương pháp truyền tệp trên Windows
- **Phần 03** — Các phương pháp truyền tệp trên Linux
- **Phần 04** — Truyền tệp bằng mã chương trình
- **Phần 05** — Các phương pháp truyền tệp khác
- **Phần 06** — Truyền tệp có bảo vệ
- **Phần 07** — Nhận tệp qua HTTP/S
- **Phần 08** — Tận dụng công cụ sẵn có trên hệ thống
- **Phần 09** — Phát hiện
- **Phần 10** — Né tránh phát hiện

Cách tổ chức bản ghi chép

Lý thuyết trong bản gốc được tổng hợp theo từng phần bằng tiếng Bồ Đào Nha Brazil, giữ nguyên logic của mô-đun và xen kẽ hai bài thực hành cuối tại những vị trí phù hợp nhất với tiến trình: sau phần phương pháp trên Windows và sau phần phương pháp trên Linux.

Phần 01 — Truyền tệp

Tóm tắt lý thuyết

Phần mở đầu xác định truyền tệp là một năng lực tác nghiệp cốt lõi trong mọi cuộc đánh giá bảo mật. Tình huống được trình bày cho thấy việc đưa tệp tới mục tiêu hoặc lấy tệp về hiếm khi diễn ra đơn giản: bộ lọc lưu lượng đi ra, việc chặn công cụ có sẵn, chính sách ứng dụng, AV/EDR, tường lửa và hạn chế giao thức có thể khiến lần thử đầu thất bại, buộc người thực hiện đổi phương án.

Thông điệp chính là truyền tệp không phải mục tiêu tự thân. Nó hỗ trợ liệt kê, chạy công cụ, leo thang đặc quyền, thu thập bằng chứng và đưa dữ liệu ra ngoài trong phạm vi được phép ở phòng lab. Vì vậy, toàn bộ mô-đun được xây dựng như một bộ phương án: càng thành thạo nhiều phương pháp, người thực hiện càng dễ tìm được đường khả thi khi HTTP, FTP, SMB, PowerShell hoặc tài nguyên khác bị môi trường hạn chế.

Điểm chính

- Truyền tệp là nhu cầu thường xuyên trong giai đoạn sau khai thác, xử lý sự cố và thu thập dữ liệu.
- Biện pháp kiểm soát trên máy và trên mạng đều ảnh hưởng tới thành công của thao tác.
- Công cụ có sẵn không đồng nghĩa với chắc chắn sử dụng được: phương pháp vẫn có thể bị giám sát hoặc chặn.
- Giá trị của mô-đun nằm ở khả năng chuẩn bị phương án dự phòng, không phải học thuộc một quy trình duy nhất.

Điều cần ghi nhớ

Trong truyền tệp, ưu thế không nằm ở việc biết một phương pháp hoàn hảo mà ở khả năng nhanh chóng chuyển giữa các phương pháp chưa hoàn hảo tùy theo môi trường.

Phần 02 — Các phương pháp truyền tệp trên Windows

Tóm tắt lý thuyết

Phần này đề cập tải xuống và tải lên trên Windows, tập trung vào công cụ và thành phần đã có trong hệ thống. Mô-đun sử dụng PowerShell, Base64, HTTP/HTTPS, SMB, FTP và WebDAV để cho thấy hệ sinh thái Windows có nhiều cách thực tế để chuyển tệp mà chưa cần dùng ngay chương trình bên ngoài.

Bên cạnh cách tải xuống thông thường bằng PowerShell, phần này nhấn mạnh thực thi trong bộ nhớ, khác biệt giữa các HTTP client, lỗi thường gặp liên quan tới thành phần Internet Explorer cũ và TLS, SMB có xác thực, tự động hóa FTP bằng tệp lệnh, cùng các cách tải lên qua HTTP và WebDAV. Bài học cốt lõi là chọn kênh theo loại shell, kết nối sẵn có, mức độ nhạy cảm của tệp và lượng dấu vết mà phương pháp thường tạo ra.

Điểm chính

- Base64 là phương án dự phòng cho tệp nhỏ và shell bị hạn chế.
- HTTP/HTTPS thường thuận tiện nhất nhưng có thể thất bại do bộ lọc, phân tích cú pháp hoặc chứng chỉ.
- SMB vẫn hữu ích trong hệ sinh thái Windows, nhưng truy cập khách và cổng 445 có thể bị chặn.
- WebDAV là phương án thay thế đáng giá khi không thể dùng SMB trực tiếp.

Điều cần ghi nhớ

Trên Windows, tải xuống và tải lên là những bài toán tương tự nhưng không giống hệt nhau: bên nhận, giao thức và xác thực có thể thay đổi hoàn toàn lựa chọn phương pháp.

Bài thực hành — Windows: tải xuống bằng wget, tải ZIP lên và tính hash trên mục tiêu

Đề bài gốc được giữ nguyên

[LAB_IP_REDACTED] - Download the file flag.txt from the web root using wget from the Pwnbox. Submit the contents of the file as your answer.
Upload the attached file named upload_win.zip to the target using the method of your choice. Once uploaded, unzip the archive, and run "hasher upload_win.txt" from the command line. Submit the generated hash as your answer.
RDP to [LAB_IP_REDACTED] (ACADEMY-MISC-MS02), with user [REDACTED] and [LAB_PASSWORD_REDACTED] [REDACTED]

Bản dịch đề bài: Từ Pwnbox, dùng wget tải flag.txt từ thư mục gốc của máy chủ web [LAB_IP_REDACTED], rồi nộp nội dung tệp. Tải tệp đính kèm upload_win.zip lên mục tiêu bằng phương pháp tùy chọn; giải nén và chạy hasher upload_win.txt trên dòng lệnh, rồi nộp hash được tạo. Kết nối RDP tới [LAB_IP_REDACTED] (ACADEMY-MISC-MS02) với người dùng [LAB_USER_REDACTED], mật khẩu [LAB_PASSWORD_REDACTED].

Kết quả cuối đã ghi nhận

- Flag trong thư mục gốc máy chủ web: [HASH_REDACTED]
- Hash của upload_win.txt: [HASH_REDACTED]

Quy trình thực hành đã tổng hợp

1. Tải flag.txt trực tiếp từ Pwnbox bằng wget và kiểm tra bằng cat, thu được giá trị cuối chính xác.
2. Thư mục chia sẻ được chuyển hướng qua \\tsclient\share cho phép liệt kê ZIP trên máy Windows, nhưng sao chép trực tiếp tới Desktop thất bại với lỗi Access is denied (truy cập bị từ chối).
3. Kiểm tra ZIP trên Pwnbox cho thấy tệp thuộc sở hữu root và không có quyền đọc phù hợp cho tiến trình python3 -m http.server.
4. Sau khi chỉnh để tệp có thể được đọc và mở máy chủ Python tại cổng 8080, máy Windows tải ZIP bằng Invoke-WebRequest vào thư mục tạm.
5. Giải nén bằng Expand-Archive và chạy hasher trên upload_win.txt, thu được hash cuối đã xác nhận.

Các lệnh và đầu ra được giữ nguyên

Tải flag ban đầu trên Pwnbox

```
wget [LAB_URL_REDACTED] -O flag.txt
cat flag.txt
```

```
[HASH_REDACTED]
```

Xác nhận lỗi sao chép qua thư mục chia sẻ được chuyển hướng

```
C:\Users\htb-student>dir \\tsclient\share
Directory of \\tsclient\share
04/20/2026 03:44 PM          194 upload_win.zip
```

```
C:\Users\htb-student>copy \\tsclient\share\upload_win.zip %USERPROFILE%\Desktop\
Access is denied.
```

Chẩn đoán tệp trên Pwnbox

```
ls -lah
-rwxr-x--- 1 root root 194 Apr 20 19:44 upload_win.zip
file upload_win.zip
upload_win.zip: regular file, no read permission
```

Tải xuống, giải nén và tính hash trên Windows

```
PS C:\Users\htb-student> iwr [LAB_URL_REDACTED] -OutFile $env:TEMP\upload_win.zip
PS C:\Users\htb-student> Expand-Archive -LiteralPath $env:TEMP\upload_win.zip -DestinationPath
$env:TEMP\upload_win -Force
PS C:\Users\htb-student> hasher $env:TEMP\upload_win\upload_win.txt
[HASH_REDACTED]
```

Phần 03 — Các phương pháp truyền tệp trên Linux

Tóm tắt lý thuyết

Phần này áp dụng cách suy luận của Windows vào hệ sinh thái Linux, ưu tiên công cụ rất phổ biến trên các bản phân phối kiểu Unix như wget, cURL, Bash, Python, máy chủ web nhẹ và SCP. Mô-đun đưa ra tình huống người tấn công thử nhiều phương pháp liên tiếp để nhấn mạnh rằng không nên phụ thuộc vào một công cụ duy nhất.

Ngoài tải xuống qua web theo cách truyền thống, phần này đề cập mã hóa/giải mã Base64, thực thi theo luồng qua pipe, phương án dự phòng /dev/tcp của Bash, SSH/SCP, tải lên qua máy chủ HTTP được chuẩn bị để nhận tệp và tạo nhanh máy chủ web bằng Python, PHP hoặc Ruby. Ý tưởng quan trọng nhất là Linux thuận lợi cho việc kết hợp: ghép các công cụ đơn giản thường giải quyết được vấn đề mà không cần thêm chương trình.

Điểm chính

- wget và cURL là nền tảng của tải xuống qua web trên Linux.
- Pipe hỗ trợ thực thi theo luồng và giảm phụ thuộc vào tệp trung gian.
- SCP là lựa chọn mạnh khi cổng 22 và thông tin xác thực hợp lệ sẵn có.
- Máy chủ HTTP tạm trên máy đã bị xâm nhập có thể đơn giản hóa việc lấy tệp về máy tấn công.

Điều cần ghi nhớ

Trên Linux, vốn phương pháp là khả năng kết hợp tiện ích sẵn có, chiều lưu lượng và sự đơn giản trong thao tác để tìm ra luồng được môi trường chấp nhận.

Bài thực hành — Linux: tải xuống bằng Python, tải lên qua scp, giải nén và tính hash trên mục tiêu

Đề bài gốc được giữ nguyên

[LAB_IP_REDACTED] Download the file flag.txt from the web root using Python from the Pwnbox. Submit the contents of the file as your answer.
Upload the attached file named upload_nix.zip to the target using the method of your choice. Once uploaded, SSH to the box, extract the file, and run "hasher <extracted file>" from the command line. Submit the generated hash as your answer.
SSH to [LAB_IP_REDACTED] (ACADEMY-MISC-NIX04), with user [REDACTED] and [LAB_PASSWORD_REDACTED]
[REDACTED] You can use gunzip to extract the file with the command: gunzip -S .zip upload_nix.zip

Bản dịch đề bài: Từ Pwnbox, dùng Python tải flag.txt từ thư mục gốc máy chủ web [LAB_IP_REDACTED], rồi nộp nội dung. Tải tệp đính kèm upload_nix.zip lên mục tiêu bằng phương pháp tùy chọn; kết nối SSH, giải nén và chạy hasher <extracted file>, rồi nộp hash. Kết nối SSH tới [LAB_IP_REDACTED] (ACADEMY-MISC-NIX04) với người dùng [LAB_USER_REDACTED], mật khẩu [LAB_PASSWORD_REDACTED]. Có thể dùng gunzip -S .zip upload_nix.zip để giải nén.

Kết quả cuối đã ghi nhận

- Flag trong thư mục gốc máy chủ web: [HASH_REDACTED]
- Hash của tệp upload_nix đã giải nén: [HASH_REDACTED]

Quy trình thực hành đã tổng hợp

1. Tải flag.txt bằng lệnh Python một dòng sử dụng urllib.request và kiểm tra cục bộ bằng cat.
2. upload_nix.zip nằm trong thư mục chia sẻ cục bộ, cần sudo để liệt kê, sao chép vào thư mục mô-đun và điều chỉnh chủ sở hữu, quyền truy cập.
3. Dù đã dùng python3 -m http.server để kiểm tra việc cung cấp ZIP cục bộ, lần truyền cuối được thực hiện trực tiếp bằng scp tới [LAB_CREDENTIAL_REDACTED] trên mục tiêu Linux.

4. Trên máy đích, giải nén bằng `gunzip -S .zip` và chạy hasher trên tệp kết quả `upload_nix`.

5. Hash cuối đã xác nhận hoàn tất bài thực hành và chứng minh luồng tải xuống, tải lên, xử lý sau truyền trên mục tiêu hoạt động đúng.

Các lệnh và đầu ra được giữ nguyên

Tải flag bằng Python trên Pwnbox

```
python3 -c "import urllib.request;
open('flag.txt', 'wb').write(urllib.request.urlopen('[LAB_URL_REDACTED]')
cat flag.txt
```

[HASH_REDACTED]

Sao chép ZIP từ thư mục chia sẻ cục bộ

```
sudo ls /[LAB_CREDENTIAL_REDACTED]
sudo cp /[LAB_CREDENTIAL_REDACTED]/upload_nix.zip ~/Desktop/HTB\ Academy\File\ Transfers
sudo chown [LAB_CREDENTIAL_REDACTED] upload_nix.zip
sudo chmod 644 upload_nix.zip
```

Truyền tệp lần cuối bằng scp

```
scp upload_nix.zip [LAB_USER_REDACTED]@[LAB_IP_REDACTED]:/[LAB_CREDENTIAL_REDACTED]
...
upload_nix.zip 100% 194 1.3KB/s 00:00
```

Giải nén và tính hash trên mục tiêu Linux

```
ssh htb-student@[LAB_IP_REDACTED]
cd /[LAB_CREDENTIAL_REDACTED] -S .zip upload_nix.zip
hasher upload_nix
```

[HASH_REDACTED]

Phần 04 — Truyền tệp bằng mã chương trình

Tóm tắt lý thuyết

Phần này cho thấy ngôn ngữ lập trình có trên máy có thể làm cơ chế truyền tệp khi tiện ích truyền thống không sẵn có hoặc không phải lựa chọn tốt nhất. Mô-đun trình bày Python, PHP, Ruby, Perl, JavaScript và VBScript như những cách tải hoặc gửi nội dung có thể lập trình bằng vài dòng mã.

Cách suy nghĩ tương tự trong hầu hết các ngôn ngữ: mở URL, lấy nội dung, xử lý dưới dạng chuỗi hoặc luồng và lưu cục bộ; hoặc gửi tệp trong yêu cầu HTTP. Trên Windows, `cscript` là bộ thực thi hữu ích cho JavaScript và VBScript; trên Linux, Python và PHP là các lựa chọn tự nhiên nhờ độ phổ biến và tính linh hoạt.

Điểm chính

- Lệnh một dòng hữu ích trong môi trường bị hạn chế và shell thiếu ổn định.
- Ngôn ngữ đã có trên máy có thể thay thế công cụ truyền tệp còn thiếu.
- Cùng cách suy luận áp dụng được cho tải xuống và tải lên, đặc biệt với HTTP GET và POST.
- Phiên bản ngôn ngữ và thư viện sẵn có làm thay đổi cú pháp và hành vi thực tế.

Điều cần ghi nhớ

Mã chương trình không chỉ phục vụ tự động hóa; trong truyền tệp, nó trở thành công cụ ứng biến khi máy đã có môi trường thực thi phù hợp.

Phần 05 — Các phương pháp truyền tệp khác

Tóm tắt lý thuyết

Phần này mở rộng các lựa chọn bằng kênh thay thế ngoài HTTP/SMB/FTP. Netcat và Ncat là tiện ích rất linh hoạt để gửi, nhận tệp qua kết nối TCP đơn giản; PowerShell Remoting và RDP cho thấy kênh quản trị từ xa cũng có thể dùng để chuyển tệp giữa các hệ thống Windows.

Điểm quan trọng nhất là chiều kết nối. Tùy khả năng tường lửa cho phép, có thể phù hợp hơn khi mục tiêu lắng nghe và máy tấn công kết nối tới, hoặc ngược lại. Trong môi trường Windows nội bộ, [LAB_CREDENTIAL_REDACTED] Remoting và RDP qua chuyển hướng tài nguyên cục bộ có thể giải quyết vấn đề mà không cần máy chủ web hỗ trợ.

Điểm chính

- Netcat/Ncat hoạt động tốt khi một bên có thể lắng nghe và bên kia có thể kết nối.
- Bash `/dev/tcp` vẫn là phương án dự phòng hữu ích khi thiếu nc/ncat.
- WinRM cho phép sao chép tệp bên cạnh thực thi lệnh từ xa.
- RDP có thể làm kênh truyền thủ công qua thư mục hoặc ổ đĩa được chuyển hướng.

Điều cần ghi nhớ

Với các phương pháp này, lựa chọn đúng thường phụ thuộc vào bên nào có thể mở kết nối và với đặc quyền nào, hơn là phụ thuộc vào công cụ.

Phần 06 — Truyền tệp có bảo vệ

Tóm tắt lý thuyết

Phần này chuyển trọng tâm từ “truyền như thế nào” sang “bảo vệ nội dung được truyền như thế nào”. Khi tệp chứa dữ liệu nhạy cảm như thông tin đăng nhập, dữ liệu xác thực hoặc bằng chứng có tác động lớn, mô-đun khuyến nghị ưu tiên kênh mã hóa như SSH, SFTP, HTTPS và khi cần, mã hóa chính tệp trước khi chuyển.

Trên Windows, ví dụ dùng script PowerShell để mã hóa và giải mã chuỗi, tệp. Trên Linux, OpenSSL thực hiện cùng vai trò với thuật toán đối xứng và mật khẩu mạnh. Phần này cũng nhấn mạnh giảm thiểu dữ liệu: trong nhiều tình huống, không cần đưa dữ liệu nhạy cảm nhất ra khỏi môi trường mới chứng minh được rủi ro.

Điểm chính

- Nội dung nhạy cảm cần được xử lý riêng trước, trong và sau khi truyền.
- Mã hóa tệp bổ sung nhưng không thay thế việc sử dụng kênh an toàn.
- Mật khẩu mạnh và riêng biệt là thành phần thiết yếu của bảo vệ.
- Giảm thiểu dữ liệu là cách làm chuyên nghiệp, không phải chi tiết tùy chọn.

Điều cần ghi nhớ

Truyền an toàn không chỉ là vấn đề giao thức: còn phải bảo vệ chính tệp và giới hạn những gì thực sự cần đưa ra khỏi môi trường.

Phần 07 — Nhận tệp qua HTTP/S

Tóm tắt lý thuyết

Phần này quay lại HTTP và HTTPS, tập trung vào nhận tệp với mức an toàn tác nghiệp tốt hơn. Thay vì chỉ dùng máy chủ đơn giản, tồn tại trong thời gian ngắn, mô-đun hướng dẫn thiết lập điểm nhận tải lên được kiểm soát tốt hơn bằng Nginx, thư mục riêng, quyền truy cập phù hợp và phương thức HTTP dành cho ghi dữ liệu.

Bài học quan trọng không chỉ là điểm nhận chấp nhận tải lên, mà còn làm được điều đó mà không gây lộ dữ liệu không cần thiết. Cần kiểm tra xung đột cổng, xem log, xác nhận tệp thực sự được ghi vào đúng thư mục và tránh để thư mục tải lên có thể được duyệt hoặc liệt kê công khai.

Điểm chính

- HTTP/S là kênh hữu ích vì thường đi qua tường lửa thuận lợi.
- Máy chủ nhận tải lên cần thư mục riêng và quyền truy cập chính xác.
- Log và xung đột khi gần cổng lắng nghe là phần bình thường của xử lý sự cố.
- Hoạt động được chưa đủ: điểm nhận tải lên còn phải an toàn.

Điều cần ghi nhớ

Khi nhận tệp qua web, bảo mật dịch vụ và mức độ lộ thư mục quan trọng ngang với việc truyền tệp.

Phần 08 — Tận dụng công cụ sẵn có trên hệ thống (Living off the Land)

Tóm tắt lý thuyết

Phần này hệ thống hóa khái niệm Living off the Land: nhiều chương trình hợp lệ của hệ thống có thể được tận dụng để tải xuống, tải lên, đọc, ghi và thực hiện chức năng hữu ích khác trong đánh giá bảo mật. Mô-đun tham chiếu dự án LOLBAS cho Windows và GTF0Bins cho Linux.

Các ví dụ CertReq, OpenSSL, Bitsadmin và Certutil củng cố logic chính: chương trình quản trị hoặc thông dụng có thể làm kênh truyền tệp thay thế khi công cụ dễ nhận biết hơn thất bại hoặc gây quá nhiều chú ý. Đồng thời, phần này nhắc rằng có sẵn không đồng nghĩa với tự động kín đáo, đặc biệt với Certutil.

Điểm chính

- LOLBAS và GTF0Bins là danh mục phương án dự phòng theo khả năng.
- Chương trình hợp lệ có thể có chức năng phụ hữu ích cho truyền tệp.
- Khác biệt về phiên bản và tham số quan trọng trong môi trường thực tế.
- Biết nhiều chương trình có sẵn giúp tăng tính linh hoạt tác nghiệp.

Điều cần ghi nhớ

Living off the Land chủ yếu là biết tận dụng nhanh những gì máy đã cung cấp sẵn, hơn là “mẹo sáng tạo”.

Phần 09 — Phát hiện

Tóm tắt lý thuyết

Phần này hoàn thiện khía cạnh tấn công bằng cách chỉ ra phương pháp truyền tệp để lại dấu vết quan sát được, đặc biệt trong dòng lệnh, HTTP header và User-Agent. Mô-đun đối chiếu danh sách lệnh bị cấm với danh sách lệnh được phép, đồng thời cho thấy các HTTP client khác nhau trong Windows tạo dấu hiệu nhận diện khác nhau dù tải cùng một tệp.

Invoke-WebRequest, WinHttpRequest, Msxml2.XMLHTTP, Certutil và BITS là ví dụ về dữ liệu giám sát khác nhau phía máy chủ. Thông điệp rõ ràng: công cụ có sẵn cũng để lại dấu hiệu đã biết. Với đội phòng thủ, đường cơ sở của User-Agent và tương quan giữa tiến trình với mạng rất hữu ích cho săn tìm mối đe dọa và phân loại ban đầu.

Điểm chính

- Phát hiện có thể xem xét dòng lệnh, HTTP header và mẫu hành vi của client.
- User-Agent hữu ích nhưng phải được diễn giải trong bối cảnh máy và tiến trình.
- Các công cụ tạo dấu hiệu khác nhau dù cùng mục tiêu tác nghiệp.
- SIEM và đường cơ sở giúp tín hiệu đơn giản có giá trị hơn nhiều trong săn tìm mối đe dọa.

Điều cần ghi nhớ

Phương pháp có sẵn không phải phương pháp vô hình: mỗi lựa chọn truyền tệp đều thay đổi dữ liệu giám sát mà đội phòng thủ có thể quan sát.

Phần 10 — Né tránh phát hiện

Tóm tắt lý thuyết

Phần cuối thảo luận ở mức khái quát vì sao tín hiệu phát hiện riêng lẻ như User-Agent hay tên chương trình được phép có thể yếu khi dùng độc lập. Mô-đun trình bày về mặt khái niệm rằng một số client cho phép thay đổi định danh HTTP và các chương trình Living off the Land có thể vượt qua chính sách quá đơn giản chỉ dựa vào danh sách tên được phép.

Từ góc nhìn phòng thủ, kết luận quan trọng nhất là phát hiện hiệu quả cần tương quan tiến trình, mạng, bối cảnh, đích đến, thao tác ghi tệp và lịch sử hành vi của máy. Vì vậy, LOLBAS và GTF0Bins không chỉ là phương án dự phòng cho tấn công: chúng còn giúp phòng thủ lập bản đồ khả năng bị lạm dụng và xây dựng phạm vi giám sát hành vi tốt hơn.

Điểm chính

- User-Agent là tín hiệu yếu nếu phân tích riêng lẻ.
- Chương trình hợp lệ không đồng nghĩa với hoạt động hợp lệ.
- Danh sách cho phép chỉ dựa trên tên tiến trình có thể thất bại.
- Tương quan tiến trình, mạng và bối cảnh có giá trị hơn một chỉ báo đơn lẻ.

Điều cần ghi nhớ

Phần kết đưa ra một kết luận phòng thủ rõ ràng: tín hiệu đơn giản có ích, nhưng bối cảnh và tương quan mới thực sự duy trì khả năng phát hiện tốt.

Kết thúc mô-đun

Mô-đun File Transfers hoàn thành một chu trình tác nghiệp rất thực tế: bắt đầu từ lý do truyền tệp là vấn đề thường gặp trong đánh giá bảo mật, đi qua các phương án chính trên Windows và Linux, mở rộng bằng mã chương trình, Netcat, RDP, WinRM và công cụ Living off the Land, rồi kết nối tất cả với bảo vệ dữ liệu, phát hiện và bối cảnh phòng thủ.

Nội dung ôn tập nhanh

- Truyền tệp hỗ trợ liệt kê, thực thi, thu thập bằng chứng và leo thang đặc quyền.
- HTTP/S, SMB, FTP, SCP, RDP, WinRM, Netcat và Base64 bổ sung cho nhau, không thay thế hoàn toàn nhau.
- Windows và Linux có nhiều phương án sẵn có hoặc gần như sẵn có để chuyển tệp.
- Tệp nhảy cảm cần giảm thiểu thu thập, kênh an toàn và khi cần, mã hóa nội dung.
- LOLBAS và GTFEBins mở rộng các lựa chọn bằng những gì đã có trên máy.
- Mỗi phương pháp thay đổi dấu vết quan sát được và ảnh hưởng đến khả năng phát hiện của môi trường.

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn

([https://\[LAB_CREDENTIAL_REDACTED\]/hack-the-box-academy-notes](https://[LAB_CREDENTIAL_REDACTED]/hack-the-box-academy-notes)). Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem `ATTRIBUTION.md` (`ATTRIBUTION.md`) và `LICENSE` (`LICENSE`).